



Weekly Cyber Threat Intelligence Report

Reporting window: 9 - 15 June 2026

Australia - APAC - Global - Emerging Threats - IOCs to Add

Prepared for: Jordan

Classification: TLP:CLEAR - cleared for public release

Source: CyberSec Vault automated intel sweep

PUBLIC

Executive Summary

13

Critical CVEs

3

High-sev vulns

8

Actively exploited

6

Notable breaches

8

PoCs / tools

13

IOCs to add

This week was dominated by **edge / enterprise zero-days feeding ransomware and data-theft**, a steady stream of **Windows 0-day PoC drops**, and **software supply-chain worms broadening across ecosystems**. Internet-facing appliances were hit hard: Ivanti Sentry (CVSS 10.0) is being mass-backdoored, a Check Point VPN zero-day (CVE-2026-50751) was tied to **Qilin** (CISA gave feds 3 days), Oracle PeopleSoft (CVE-2026-35273) and a new on-prem Exchange 0-day (CVE-2026-42897) were exploited by **ShinyHunters** and others, and Microsoft shipped its largest-ever Patch Tuesday (~204 vulns, 3 zero-days). The 'Nightmare Eclipse' actor released working PoCs for a Defender SYSTEM exploit (**RoguePlanet**) and a BitLocker bypass (**GreatXML**). Supply-chain worms expanded - Shai-Hulud (19 PyPI packages), IronWorm/Miasma (npm + 73 Microsoft repos, source leaked), and ~879 compromised Arch AUR packages - while **AI/LLM infrastructure** (LiteLLM CVSS-10 RCE, Langflow, the OpenClaw agent) is now squarely in scope. China-nexus espionage stayed visible (Velvet Ant's decade-long PAM/OpenSSH backdoor; JDY/Volt Typhoon). Regionally: Mackay Sugar's Queensland mills were shut by a cyberattack, and APAC saw a record ~\$409M Coupang fine and a 10.9M-customer Kyushu Electric exposure. **Items are ordered verified-first, each with up to three independent references**; public PoCs/tool releases and indicators to add to blocklists/SIEM are called out in their own sections.

AUSTRALIA - SPECIFIC

Local orgs & data

Mackay Sugar (AU) - cyberattack shuts major mills, halts harvest

HIGH

VERIFIED

Breach

OT

Agriculture

Mackay Sugar - Australia's second-largest sugar producer - shut its Farleigh and Racecourse mills in Queensland after a cyber incident days into the 2026 crushing season, halting milling, cane haulage and harvesting. External IR experts and authorities engaged; attack type (ransomware/data theft) undisclosed. A clear agri-industrial OT disruption case.

Refs: therecord.media · industrialcyber.co · securityboulevard.com

APAC - SPECIFIC

Regional incidents & actors

Velvet Ant (China-nexus) - decade-long PAM / OpenSSH auth-stack backdoor (Operation Highland)

HIGH

VERIFIED

APT

China

CredTheft

Sygnia (tracking the actor as Velvet Ant) found a China-nexus group hidden ~10 years by trojanising the Linux login stack itself - replacing ssh/sshd/scp and PAM modules (nine versions) to capture credentials, log session commands and add secret-password backdoors. Begun in 2016, it pivoted into an air-gapped network. Detection requires binary/package-integrity verification (rpm -V / dpkg --verify), not file-based IOC hunting.

Refs: bleepingcomputer.com · thehackernews.com · sygnia.co

JDY botnet (China-linked, Volt Typhoon) - expands targeting of US military networks

HIGH

VERIFIED

Botnet

China

Recon

The China-nexus JDY botnet (tied to Volt Typhoon) grew to 1,500+ compromised SOHO/IoT devices (Cisco, Ubiquiti, DrayTek, Hikvision and others) and operates as a distributed scanning/recon network - service discovery, banner grabbing, TLS-cert collection and flaw-focused recon - with most scanned IPs on US military networks. C2 runs over hidden Tor services; consistent with living-off-the-land pre-positioning.

Refs: bleepingcomputer.com · thehackernews.com · lumen.com

Coupang (South Korea) - record ~\$409M PIPC fine over 37.5M-customer breach

HIGH

VERIFIED

Breach

Korea

Regulatory

South Korea's PIPC fined Coupang a record ~624.6bn won (~\$409M) after a breach exposing 37.5 million customers. Regulators blamed basic safety-management failures (poor signing-key management, lax access controls) rather than a sophisticated hack; the prime suspect is a former Coupang IT insider. A signal of increasingly aggressive APAC data-protection enforcement.

Refs: bleepingcomputer.com · therecord.media · scmp.com

Kyushu Electric (Japan) - lost unencrypted SSD exposes 10.9M customers

MEDIUM

VERIFIED

Breach

Japan

A Kyushu Electric subsidiary lost a palm-sized SSD - neither encrypted nor password-protected - holding records of up to 10.9 million customers (names, addresses, phone numbers, usage data). A contractor copied backups to the drive in April; it went missing from an unlocked cabinet in a secured server room. Reportedly the largest personal-data breach in Japanese history; a reminder to enforce full-disk encryption on removable media.

Refs: bleepingcomputer.com · scworld.com · techradar.com

GLOBAL - ACTIVELY EXPLOITED & CRITICAL CVEs

[Patch now](#)**CVE-2026-10520 - Ivanti Sentry OS command injection (CVSS 10.0), mass-exploited**

CRITICAL

VERIFIED

Appliance

RCE

Exploited

Unauthenticated OS command injection to root RCE on internet-facing Ivanti Sentry gateways. Exploitation began ~24h after a public PoC; Shadowserver reports mass backdooring of exposed instances. Patch per Ivanti advisory and assume compromise - hunt for webshells, rotate secrets.

PoC: **Public - Nuclei template; active mass backdooring (assume compromise) - [github.com](#)**

Refs: [bleepingcomputer.com](#) · [hub.ivanti.com](#) · [x.com/IntCyberDigest](#)

CVE-2026-35273 - Oracle PeopleSoft unauth RCE 0-day (ShinyHunters / UNC6240)

CRITICAL

VERIFIED

RCE

ZeroDay

Exploited

Critical unauthenticated PeopleTools flaw (CVSS 9.8, SSRF chained to RCE) exploited by ShinyHunters/UNC6240 since ~27 May, predating Oracle's advisory by two weeks. ~300 PeopleSoft instances compromised across 100+ orgs (about 68% US academic), with data published on the gang's leak site. Apply Oracle mitigations; treat internet-exposed instances as compromised and hunt PSEMHUB endpoints.

PoC: **Active exploitation in the wild (since late May; ~300 instances)**

Refs: [bleepingcomputer.com](#) · [rapid7.com](#) · [securityweek.com](#)

CVE-2026-42897 - Microsoft Exchange on-prem 0-day (OWA spoofing/XSS), exploited & patched

CRITICAL

VERIFIED

Exchange

ZeroDay

Exploited

Actively exploited on-prem Exchange spoofing flaw (CVSS 8.1) - an OWA XSS where a weaponized email runs JavaScript in the victim's browser session, enabling spoofing, credential/session theft. Affects Exchange 2016/2019/SE (not Exchange Online). Microsoft has shipped a patch; the Exchange Emergency Mitigation service (on by default) also mitigates - apply both and prioritise internet-facing servers.

PoC: **Active exploitation via weaponized email**

Refs: [bleepingcomputer.com](#) · [securityweek.com](#) · [infosecurity-magazine.com](#)

CVE-2026-50751 - Check Point RA VPN auth-bypass 0-day, Qilin (CISA 3-day)

CRITICAL

VERIFIED

VPN

Ransomware

Exploited

Critical authentication-bypass flaw (CVSS 9.3) in Check Point Remote Access / Mobile Access, exploited as a zero-day since ~7 May and tied to a Qilin ransomware affiliate. Affects gateways using the deprecated IKEv1 flow without a required machine certificate. Added to CISA KEV with a 3-day federal patch deadline - edge VPN remains the leading ransomware on-ramp.

PoC: **Active exploitation in the wild (since ~7 May)**

Refs: [bleepingcomputer.com](#) · [helpnetsecurity.com](#) · [rapid7.com](#)

Windows Defender 'RoguePlanet' 0-day - public exploit grants SYSTEM

CRITICAL

VERIFIED

Windows

PrivEsc

EDR-Bypass

The 'Nightmare Eclipse' researcher published 'RoguePlanet', a working exploit abusing Microsoft Defender to escalate to SYSTEM, under a new GitHub alias - the latest in the recurring 'Eclipse' Defender 0-day saga (cf. three exploited Defender flaws incl. CVE-2026-33825). Treat as actively weaponised; monitor MSRC, keep Defender platform current, hunt for Defender process anomalies / SYSTEM escalations.

PoC: **Public - SYSTEM exploit on GitHub (Nightmare Eclipse) - [github.com](#)**

Refs: [bleepingcomputer.com](#) · [x.com/DarkWebInformer](#) · [x.com/TheHackersNews](#)

GreatXML - Windows BitLocker bypass 0-day via WinRE / Defender Offline

CRITICAL

VERIFIED

Windows

BitLocker

ZeroDay

GreatXML abuses the Windows Recovery Environment + Defender Offline scan workflow to break into an unrestricted shell and access BitLocker-encrypted drives with no recovery key and no cracking. Same Nightmare Eclipse actor behind RoguePlanet; PoC re-dropped from a fresh GitHub account after takedowns. Mitigate with pre-boot auth (TPM + PIN) and WinRE hardening (mostly a local/physical-access risk).

PoC: Public - PoC re-released on GitHub (Nightmare Eclipse) - [x.com/IntCyberDigest](#)

Refs: [x.com/TheHackersNews](#) · [x.com/IntCyberDigest](#) · [x.com/0x534c](#)

LiteLLM chained unauth RCE (CVE-2026-42271 + CVE-2026-48710) - exploited (CVSS 10)

CRITICAL

VERIFIED

AI/LLM

RCE

Exploited

Attackers chain a LiteLLM MCP test-endpoint command injection (CVE-2026-42271) with a Starlette Host-header bypass (CVE-2026-48710) for unauthenticated RCE on the AI gateway (combined CVSS 10.0). Affects LiteLLM 1.74.2-1.83.6 with Starlette <=1.0.0; fixed in LiteLLM 1.83.7 / Starlette 1.0.1. Update now, restrict proxy exposure, rotate reachable provider API keys.

PoC: Active exploitation in the wild

Refs: [cybersecuritynews.com](#) · [thehackernews.com](#) · [rescana.com](#)

CVE-2026-20253 - Splunk Enterprise pre-auth RCE via PostgreSQL sidecar (CVSS 9.8)

CRITICAL

VERIFIED

RCE

PreAuth

A built-in Splunk database service exposed with zero authentication lets unauthenticated attackers create/truncate arbitrary files via a PostgreSQL sidecar endpoint, chaining to remote code execution. Affects versions below 10.2.4 / 10.0.7 - patch and keep management/DB ports off untrusted networks.

Refs: [thehackernews.com](#) · [x.com/SecAlertsCo](#) · [x.com/The_Cyber_News](#)

CVE-2026-11645 - Google Chrome V8 zero-day exploited (5th of 2026)

CRITICAL

VERIFIED

Browser

ZeroDay

Exploited

Google shipped an emergency out-of-band Chrome update for CVE-2026-11645, a high-severity out-of-bounds read/write in the V8 JavaScript engine exploited via crafted HTML - the fifth in-the-wild Chrome 0-day of 2026. Patched build 149.0.7827.102+. Force-update the fleet and all Chromium browsers (Edge, Brave).

PoC: Active exploitation in the wild

Refs: [bleepingcomputer.com](#) · [securityweek.com](#) · [securityaffairs.com](#)

CVE-2026-41089 - Windows Netlogon 0-click unauth RCE (CVSS 9.8), exploited

CRITICAL

VERIFIED

Windows

Netlogon

Exploited

Stack buffer overflow in Windows Netlogon (CVSS 9.8) - 0-click, unauthenticated, network-exploitable against domain controllers (Server 2012-2025), yielding SYSTEM-level RCE and domain-level compromise. Patched in the May 2026 cumulative updates and now under active exploitation per Belgium's CCB and other agencies - prioritise DC patching.

PoC: Active exploitation in the wild (DC compromise)

Refs: [bleepingcomputer.com](#) · [helpnetsecurity.com](#) · [securityweek.com](#)

Microsoft June 2026 Patch Tuesday - ~204 vulns, 3 zero-days, 38 critical

CRITICAL

VERIFIED

Microsoft

PatchTuesday

ZeroDay

Microsoft's largest Patch Tuesday on record shipped fixes for ~198-204 vulnerabilities including three publicly disclosed zero-days and 38 critical. Prioritise the disclosed 0-days and critical fixes; deploy Win10 (ESU)/Win11 cumulative updates and track Secure Boot certificate expiry this month.

Refs: [bleepingcomputer.com](#) · [isc.sans.edu](#) · [therecord.media](#)

SAP June 2026 Patch Day - 4 critical (NetWeaver, ABAP, Commerce Cloud)

CRITICAL

VERIFIED

SAP

Enterprise

SAP patched 15 vulnerabilities including four critical: CVE-2026-44748 (9.9, XML Signature Wrapping / auth bypass in NetWeaver AS ABAP), CVE-2026-27671 (9.8, memory corruption), CVE-2026-22732 (9.1, Spring Security in Commerce Cloud/Data Hub) and CVE-2026-40128 (9.0, NetWeaver AS Java directory traversal). Apply the June notes, prioritising the four critical; inventory internet-exposed instances.

Refs: [bleepingcomputer.com](#) · [securityweek.com](#) · [cybersecuritynews.com](#)

CVE-2026-44963 - Veeam Backup & Replication RCE on domain-joined servers (CVSS 9.4)

CRITICAL

VERIFIED

Backup

RCE

Any authenticated domain user can achieve RCE on domain-joined Veeam Backup & Replication servers (CVSS 9.4; affects v12-12.3.2.4465, not 13.x) - a prime ransomware target with a notably low privilege bar. Fixed in 12.3.2.4854 (KB4696, 9 Jun). Patch now; where feasible keep backup servers off the domain and verify immutable/offline copies.

Refs: [bleepingcomputer.com](#) · [thehackernews.com](#) · [csoonline.com](#)

GLOBAL - OTHER NOTABLE VULNERABILITIES

High severity

CVE-2026-5027 - Langflow path traversal -> unauth RCE (exploited, VulnCheck KEV)

HIGH

VERIFIED

AI/LLM

PathTraversal

Exploited

A path traversal in Langflow's POST /api/v2/files endpoint (CVSS 8.8) lets unauthenticated attackers write files to arbitrary locations and escalate to RCE; Langflow's default unauthenticated auto-login widens exposure (~7,000 internet-facing instances). Added to VulnCheck KEV on 8 Jun. Update and keep Langflow behind authentication/VPN.

PoC: Active exploitation in the wild (~7,000 exposed instances)

Refs: [bleepingcomputer.com](#) · [securityweek.com](#) · [thehackernews.com](#)

CVE-2026-0273 - Palo Alto PAN-OS command injection as root (authenticated admin)

HIGH

VERIFIED

Firewall

CmdInjection

An authenticated PAN-OS administrator can run arbitrary OS commands as root via the CLI or web UI (CVSS v4 6.1). Affects PA-/VM-Series and Panorama on PAN-OS 12.1/11.2/11.1/10.2 below the fixed hotfixes (Cloud NGFW / Prisma Access unaffected). Strong post-compromise leverage on the network edge - apply the fix and restrict management-plane access.

Refs: [cybersecuritynews.com](#) · [gbhackers.com](#) · [security.paloaltonetworks.com](#)

Clickjacking defenses - 3-year framing-header adoption study (SANS ISC)

MEDIUM

UNVERIFIED

WebSec

Clickjacking

Research

SANS ISC revisited anti-framing protections (X-Frame-Options and CSP frame-ancestors) across the top 1M domains. Relevant to clickjacking triage: missing/permissive headers on pages with sensitive actions remain a valid finding - pair with a working PoC to demonstrate impact. Single-source research diary (not an incident); retained as unverified.

Refs: [isc.sans.edu](#)

GLOBAL - SOFTWARE SUPPLY CHAIN

Worm wave

Shai-Hulud - 19 science PyPI packages / 37 poisoned wheels

CRITICAL

VERIFIED

PyPI

CredTheft

A new Shai-Hulud wave trojanised 19 science-focused PyPI packages (hundreds of thousands of downloads, ~37 malicious wheels) that steal developer secrets and run at Python interpreter startup - before any import. Part of the Shai-Hulud / Mini Shai-Hulud (TeamPCP) lineage. Pin & hash-verify deps, audit startup hooks (.pth/sitecustomize), rotate secrets.

Refs: [bleepingcomputer.com](#) · [x.com/TheHackersNews](#) · [isc.sans.edu](#)

IronWorm / Miasma - self-replicating npm worm (source code leaked)

CRITICAL

VERIFIED

npm

Worm

Self-propagating npm worm (Rust payloads, eBPF rootkit, Tor C2) that exfiltrates AWS/GCP/AI-provider keys; GitHub disabled 73 Microsoft repos pushing the password-stealing malware. The Miasma framework source briefly leaked on GitHub - expect derivative campaigns. Remove @asteroiddao packages and rotate all CI/cloud secrets.

Refs: bleepingcomputer.com · thehackernews.com · bleepingcomputer.com

Arch Linux AUR - ~879 packages compromised with infostealer malware

CRITICAL

VERIFIED

AUR

CredTheft

Attackers hijacked abandoned AUR projects and altered build scripts; the count climbed from 400+ to ~879 infected packages (per Arch's aur-general disclosure). Payload steals developer secrets, tokens and SSH keys and can deploy an eBPF rootkit if built as root. Treat any AUR package built after 11 Jun as suspect - rebuild from clean sources and rotate secrets.

Refs: x.com/TheHackersNews · x.com/IntCyberDigest · x.com/The_Cyber_News

npm 12 - install scripts disabled by default (supply-chain defense)

INFO

VERIFIED

npm

Defense

npm 12 (expected July) sets allowScripts off by default - npm install will no longer run preinstall/install/postinstall scripts from dependencies without explicit approval, and Git/remote-URL deps require approval. Directly targets the lifecycle-script vector used by recent worms; aligns npm with Yarn/pnpm/Bun. Audit which deps genuinely need install scripts and whitelist only those.

Refs: thehackernews.com · bleepingcomputer.com · securityweek.com

GLOBAL - PUBLIC PoCs & OFFENSIVE TOOL RELEASES

PoC / exploit code & tools

RoguePlanet - public Windows Defender -> SYSTEM exploit repo

WATCH

VERIFIED

PoC

PrivEsc

ZeroDay

Nightmare Eclipse published a working Defender SYSTEM-privilege exploit on a new GitHub alias. Repos in this cluster are repeatedly taken down and re-uploaded; capture IOCs for IR and expect opportunistic reuse.

Refs: github.com · bleepingcomputer.com · x.com/DarkWebInformers

GreatXML - public BitLocker-bypass 0-day PoC (WinRE / Defender Offline)

WATCH

VERIFIED

PoC

BitLocker

ZeroDay

PoC code for the GreatXML full-disk-encryption bypass was re-released from a fresh GitHub account after prior takedowns. Defeats BitLocker without the recovery key; primarily a local/physical-access risk - enforce TPM + PIN pre-boot auth.

Refs: x.com/IntCyberDigest · x.com/TheHackersNews · x.com/0x534c

depX (ProjectDiscovery) - supply-chain intelligence CLI

INFO

UNVERIFIED

Tool

Defense

SupplyChain

Open-source terminal-native checker that flags hijacked publishes, credential stealers and install-script backdoors in your dependency tree, backed by a live malicious-package feed. Fits CI / pre-install gating and incident triage - timely given the Shai-Hulud / Miasma / AUR waves. Single-source vendor announcement (unverified).

Refs: x.com/pdiscoveryio

CloudRip - Cloudflare origin-IP discovery (red-team recon)

INFOUNVERIFIEDToolRecon

Recon tool that uncovers the true origin server IP behind Cloudflare-fronted domains (historical DNS, cert SANs, subdomain enum), enabling WAF/DDoS bypass to hit the backend directly. Defenders should firewall origins to accept only Cloudflare IP ranges. Single-source release (unverified).

Refs: [github.com](#) · [x.com/tom_doerr](#)

Web-Check - all-in-one website OSINT / recon

INFOUNVERIFIEDToolOSINTRecon

Browser-based inspection tool that consolidates IP, SSL/TLS, DNS, cookies, WHOIS, robots.txt, server location, redirect chains and headers from a single lookup - a fast first-look recon / footprinting aid. Single-source mention (unverified).

Refs: [x.com/AIExplorerTim](#)

OSINT-Mapping-Tool - entity/relationship + geo link analysis

INFOUNVERIFIEDToolOSINT

Open-source, browser-based OSINT relationship-mapping tool (social accounts, phone numbers, vehicles, locations) for link analysis - a Maltego-style aid for investigations. Single-source release (unverified).

Refs: [github.com](#) · [x.com/QingQ77](#)

Shodan Certificate Transparency hostnames API (ctl.shodan.io)

INFOUNVERIFIEDToolReconCT

Free Shodan endpoint returning all hostnames for a domain from Certificate Transparency logs - passive, stealthy subdomain enumeration / attack-surface mapping without active scanning. Single-source announcement (unverified).

Refs: [book.shodan.io](#) · [x.com/shodanhq](#)

Dark Web OSINT tools - curated collection

INFOUNVERIFIEDToolOSINTDarkWeb

Curated collection of dark web OSINT tooling for crawling/searching onion services - useful for leaked-credential monitoring and threat-actor tracking. Run via isolated/Tor-routed VM and vet tool provenance first. Single-source mention (unverified).

Refs: [github.com](#) · [x.com/tom_doerr](#)

GLOBAL - MALWARE & CAMPAIGNS

Greatness PhaaS - AiTM + device-code phishing resurgence vs Microsoft 365

HIGHVERIFIEDPhishingPhaaSOAuth

ANY.RUN flagged renewed Greatness Phishing-as-a-Service activity combining adversary-in-the-middle with OAuth device-code phishing to capture Microsoft 365 tokens/sessions rather than passwords - bypassing MFA. Greatness (documented since 2023) sits within a broader 2026 device-code PhaaS surge (e.g. EvilTokens). Disable device-code flow where unneeded, alert on device-code auths from unexpected users/locations, and move to phishing-resistant MFA (FIDO2/passkeys).

Refs: [x.com/anyrun_app](#) · [hornetsecurity.com](#) · [blog.sekoia.io](#)

OpenClaw AI email agent (Varonis 'Pinchy') - falls for phishing, leaks data

MEDIUM

VERIFIED

AI

PromptInjection

AgentSecurity

Varonis Threat Labs built an OpenClaw email agent ('Pinchy', on Gemini/Codex models) wired to Gmail, browser tools and Workspace APIs, then ran classic phishing lures. A fake 'team lead' urgency email made the agent ignore its guardrails and hand over a CRM export (247 enterprise customers, \$1.28M MRR). Treat inbound content as untrusted, scope tools least-privilege, and require human-in-the-loop for send/forward actions.

Refs: bleepingcomputer.com · thenextweb.com · techradar.com

GLOBAL - NOTABLE BREACHES**ServiceNow - unauthenticated API exposed customer instance data**

HIGH

VERIFIED

SaaS

API

BrokenAccessControl

ServiceNow disclosed an incident where the `/api/now/related_list_edit/create` endpoint was configured with `requires_authentication=false`, letting unauthenticated requests query customer instance data (primarily Australia-platform releases). Patched 5 Jun; activity traced to 2-3 Jun and likely tied to bug-bounty research. Confirm the fix applied, review API access logs, rotate integration tokens, and assess queryable-table exposure.

Refs: bleepingcomputer.com · socradar.io · rescana.com

University of Nottingham - 455k student/alumni records breached (ShinyHunters)

HIGH

VERIFIED

Breach

Education

UK

The University of Nottingham confirmed a breach of its student-records platform affecting ~455,000 students and alumni; ShinyHunters claimed ~40GB stolen (names, addresses, financial/payment data, NI numbers) and that the Malaysia and China campuses were also hit. Reported to the ICO and Action Fraud - part of the wider ShinyHunters campaign also tied to the Oracle PeopleSoft 0-day.

Refs: bleepingcomputer.com · therecord.media · securityweek.com

French government Tchap messaging breached via hijacked account (73k accounts)

MEDIUM

VERIFIED

Government

AccountTakeover

E2EE

DINUM/ANSSI detected (7 Jun) attackers using a social-engineered, hijacked agent account to access Tchap, France's Matrix/Element-based government messenger - not a crypto break. The actor claims 73,000+ accounts and 643,000 messages; officials say E2E-encrypted private chats were unaffected (claims unverified). Underscores that E2EE offers no protection against compromised accounts - enforce MFA and monitor anomalous logins.

Refs: bleepingcomputer.com · helpnetsecurity.com · securityaffairs.com

INDICATORS OF COMPROMISE (IOCs) TO ADD

Blocklist / SIEM

Indicator	Type	Context	Reference
CVE-2026-10520	CVE	Ivanti Sentry OS cmd injection (10.0) - mass-exploited/backdoored	bleepingcomputer.com
CVE-2026-35273	CVE	Oracle PeopleSoft unauth RCE 0-day (9.8); ShinyHunters	rapid7.com
CVE-2026-42897	CVE	MS Exchange on-prem OWA spoofing/XSS 0-day (8.1); patched	bleepingcomputer.com
CVE-2026-50751	CVE	Check Point RA VPN auth bypass 0-day (9.3); Qilin	helpnetsecurity.com
CVE-2026-20253	CVE	Splunk unauth file create/truncate -> RCE (9.8); fix 10.2.4/10.0.7	thehackernews.com
CVE-2026-41089	CVE	Windows Netlogon 0-click unauth RCE (9.8); exploited - patch DCs	bleepingcomputer.com

Indicator	Type	Context	Reference
CVE-2026-44963	CVE	Veeam B&R; domain-user RCE (9.4); fix 12.3.2.4854	thehackernews.com
CVE-2026-11645	CVE	Chrome V8 OOB 0-day; build 149.0.7827.102+	securityweek.com
CVE-2026-5027	CVE	Langflow path traversal -> RCE (exploited; VulnCheck KEV)	securityweek.com
github[.]com/MSNightmare/RoguePlanet	URL (PoC)	Windows Defender -> SYSTEM exploit repo (Nightmare Eclipse)	bleepingcomputer.com
@asteroiddao (npm namespace)	Malicious packages	IronWorm / Miasma self-replicating worm; rotate CI secrets	bleepingcomputer.com
Shai-Hulud (19 sci PyPI pkgs / 37 wheels)	Malicious packages	PyPI supply-chain; runs at Python startup	bleepingcomputer.com
Arch AUR pkgs built after 2026-06-11 (~879)	Malicious packages	Infostealer + eBPF rootkit; rebuild & rotate secrets	thehackernews.com

Defanged indicators - re-fang before importing. Verify against your environment before blocking.

TRENDS & EMERGING THREATS TO WATCH

Forward look

HIGH

Edge / enterprise appliance zero-days feeding ransomware & data theft

Why it matters: Ivanti Sentry (10.0, mass-backdoored), Check Point VPN -> Qilin, Oracle PeopleSoft -> ShinyHunters, on-prem Exchange, Veeam and SAP all landed this week. Perimeter and enterprise apps remain the fastest path from zero-day to extortion.

Watch for: unpatched VPN/gateway/backup/ERP firmware; CISA KEV additions; anomalous appliance logins; new local admin accounts; webshells on internet-facing servers.

HIGH

Windows 0-day PoC factory (Nightmare / Chaotic Eclipse)

Why it matters: The same actor cluster keeps dropping working Windows exploits - RoguePlanet (Defender -> SYSTEM) and GreatXML (BitLocker bypass) this week - re-uploading repos after takedowns. Public PoCs compress the time from disclosure to opportunistic abuse.

Watch for: Defender process anomalies and SYSTEM escalations; unexpected WinRE boots / offline-scan abuse; new GitHub repos in the Eclipse cluster; out-of-band MSRC advisories.

HIGH

Software supply-chain worms broadening across ecosystems

Why it matters: Shai-Hulud (PyPI), IronWorm/Miasma (npm, source leaked, 73 MS repos) and ~879 Arch AUR packages all execute at install/startup and steal CI/cloud/AI secrets. The Miasma source leak invites copycats; npm 12 will disable install scripts by default in response.

Watch for: dependency installs that execute on import/startup; .pth / sitecustomize hooks; unexpected outbound from build agents; new maintainer tokens; AUR/npm/PyPI installs in the last 2 weeks.

MED

AI / LLM infrastructure as a first-class attack surface

Why it matters: LiteLLM (CVSS 10) and Langflow path-traversal were exploited in the wild, and the OpenClaw agent leaked CRM data to a phishing email - AI gateways, dev platforms and autonomous agents are now routinely targeted.

Watch for: exposed LLM gateways/proxies and AI dev platforms; API-key sprawl on AI hosts; agents that act on untrusted inbound content without human-in-the-loop.

MED

China-nexus espionage & long-dwell pre-positioning

Why it matters: Velvet Ant's ~10-year PAM/OpenSSH auth-stack backdoor (Operation Highland) and the JDY/Volt Typhoon botnet's expanded US-military recon show patient, living-off-the-land access that evades file-based detection.

Watch for: PAM module / sshd binary drift vs package checksums; credential-logging behaviour from auth processes; SOHO/IoT device scanning; LOTL activity on edge devices.

MED

OAuth device-code & AiTM phishing bypassing MFA

Why it matters: Greatness PhaaS resurfaced (alongside EvilTokens) combining adversary-in-the-middle with device-code phishing to steal Microsoft tokens/sessions rather than passwords - defeating traditional MFA.

Watch for: device-code authentications from unexpected users/locations; OAuth token grants on the device_code flow; absence of phishing-resistant MFA (FIDO2/passkeys).

PRIORITY ACTIONS THIS WEEK

Area	Action
Patch now	Ivanti Sentry (CVE-2026-10520); Check Point RA VPN (CVE-2026-50751); Oracle PeopleSoft (CVE-2026-35273); on-prem Exchange (CVE-2026-42897); Splunk -> 10.2.4/10.0.7 (CVE-2026-20253); Windows June PT incl. Netlogon (CVE-2026-41089) & Chrome (CVE-2026-11645); Veeam (CVE-2026-44963); SAP NetWeaver/Commerce; PAN-OS (CVE-2026-0273); Langflow (CVE-2026-5027).
Block IOCs	Add the IOC-table indicators (CVE IDs, RoguePlanet/GreatXML PoC repos, @asteroiddao / Shai-Hulud / Arch AUR malicious packages) to firewall/EDR/SIEM blocklists and alert on the listed CVEs.
Assume compromise	Treat internet-exposed Ivanti Sentry, Oracle PeopleSoft and Exchange as potentially compromised - hunt for webshells/backdoors, anomalous DB access and exfil; rotate appliance secrets.
Supply chain	Pin + hash-verify dependencies; scan for install/startup hooks; rebuild AUR/npm/PyPI installs from the last 2 weeks; rotate developer & CI/cloud secrets; pilot npm 12 / deploy depx in CI.
Windows endpoints	Keep Defender platform/signatures current; enforce BitLocker TPM + PIN pre-boot auth and harden WinRE; hunt for Defender process anomalies and SYSTEM escalations.
Identity & AI	Disable OAuth device-code flow where unneeded and move to FIDO2/passkeys; restrict exposure of LLM gateways (LiteLLM) and AI dev platforms (Langflow) and rotate reachable API keys.
People & vendors	Brief staff on AiTM/device-code phishing and fake AI-tool lures; re-review third-party DB access for AU/APAC entities (ServiceNow, vendor sub-processors).